

Ağ Trafiği Anomali Tespiti

Maliyet Odaklı Siber Güvenlik Modeli

64.910 Toplam Paket	%86.9 Accuracy	AUC 0.825 ROC Skoru	88.965 TL Net Tasarruf
-------------------------------	--------------------------	-------------------------------	----------------------------------

Python ile Veri Bilimi
Abdulkadir Kuvetli

1. Giriş

Kurumsal ağlarda günde milyonlarca paket akar; bu projedeki veri setinde 64.910 paketin %94.4'ü normal trafik, %5.6'sı ise Nmap port tarama saldırısıdır. Bu dengesizlik, geleneksel kural tabanlı sistemlerin yetersiz kalmasının temel nedenidir.

Projenin çözdüğü iki kritik sorun şöyledir: Yanlış Alarm (FP), normal trafiği saldırı olarak işaretlemek anlamına gelir ve her alarm SOC analistinin 15 dakikasını tüketir (117 TL). Kaçırılan Saldırı (FN) ise gerçek bir tehdidi atlamak demektir; KVKK çerçevesinde bu risk 300.000 TL × %0.5 olasılık ile 1.500 TL'ye karşılık gelir. Bu iki maliyet arasındaki dengeyi finansal olarak optimize etmek projenin odak noktasıdır.

2. Veri ve Yöntem

2.1 Veri Kaynakları ve Data Fusion

İki bağımsız kaynak bir araya getirilmiştir. Birinci kaynak, kendi ağımızdan toplanan Wireshark trafiğidir: 61.256 normal paket ve 3.654 saldırı paketi. İkinci kaynak, IANA'nın resmi port/servis veritabanıdır; 6.261 benzersiz port kaydına NLP tabanlı anahtar kelime analizi uygulanarak her porta Kritik (95 puan) ile Düşük (15 puan) arasında bir tehdit risk skoru atanmıştır. Birleştirme sonucunda satırların %71.9'u IANA kaydıyla eşleşmiştir.

Bu harmanlama sayesinde model yalnızca paket hacmine değil, hangi servisin hedef alındığına da bakabilmektedir. Örneğin SSH (port 22) veya RDP (port 3389) gibi kritik servislere yönelik trafik, HTTP trafiğinden çok daha yüksek risk skoru taşımaktadır.

2.2 Özellik Mühendisliği

Saldırıları tek bir paketin özelliğiyle değil, kaynak IP'nin tüm oturum davranışıyla belli olur. Aşağıdaki 8 özellik üretilmiştir:

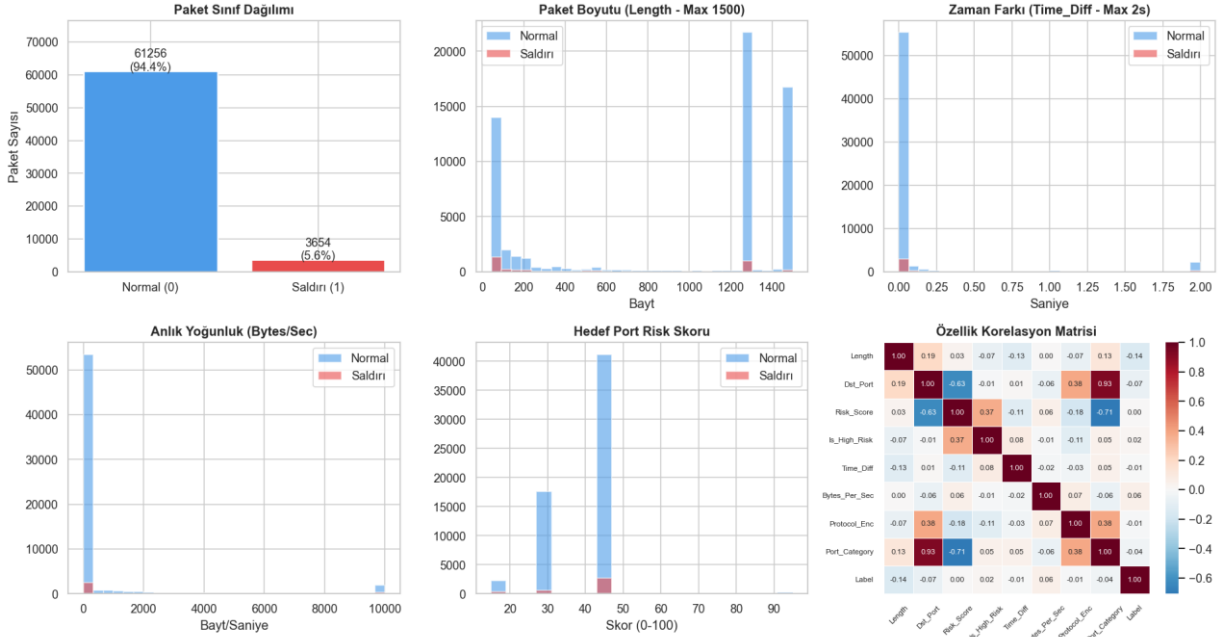
Özellik	Tanım	Normal → Saldırı Farkı
Length	Paket boyutu	940 bayt → 566 bayt (-%40)
Time_Diff	Paketler arası süre	1.12 s → 0.81 s (-%28)
Bytes_Per_Sec	Anlık veri yoğunluğu	1.497 → 3.536 B/s (+%136)
Dst_Port	Hedef port numarası	SHAP önemi #1
Risk_Score	IANA tehdit puanı (0–100)	İki sınıf benzer (39.7 vs 39.9)
Protocol_Enc	Protokol sayısal kodu	SHAP önemi #3
Is_High_Risk	Risk_Score ≥ 80 bayrağı	Modelde etkisiz (SHAP ≈ 0)
Port_Category	Port aralığı sınıfı	Modelde etkisiz (SHAP ≈ 0)

2.3 Model Eğitimi

Veri %80 eğitim / %20 test olarak bölünmüş, saldırı paketlerinin her iki sete eşit dağılması için stratified split kullanılmıştır. Eğitim setinde sınıf dengesizliğini gidermek amacıyla under-sampling uygulanmış; normal paket sayısı saldırı sayısının 2 katına indirilmiştir (8.769 paket). Random Forest (F1: 0.3026) ve XGBoost (F1: 0.3034) karşılaştırılmış, XGBoost şampiyon seçilmiştir.

3. Keşifçi Veri Analizi

Keşifçi Veri Analizi — Paket Bazlı Ağ Trafik Profilleri

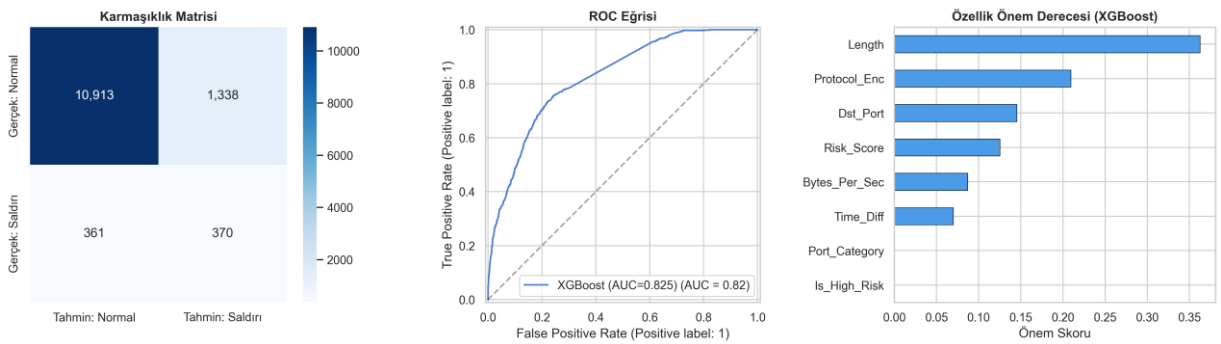


Şekil 1: Sınıf dağılımı, paket boyutu, zaman farkı, veri yoğunluğu, risk skoru dağılımı ve korelasyon matrisi

Grafikler birkaç önemli davranışsal farkı net biçimde ortaya koymaktadır. Saldırı paketleri %40 daha küçük boyuttadır (ortalama 566 bayt), çünkü SYN flood ve port tarama saldırıları çok sayıda küçük paket göndererek çalışır. Aynı saldırılar %28 daha kısa aralıklarla gelir ve saniyede 2.4 kat daha fazla veri üretir. Korelasyon matrisinde Dst_Port ile Port_Category arasındaki 0.93 korelasyon türetilmiş bir ilişkiyi yansıtır ve çoklu bağlantı (multicollinearity) sorunu oluşturmaz.

4. Model Performansı

Model Performans Göstergeleri — XGBoost



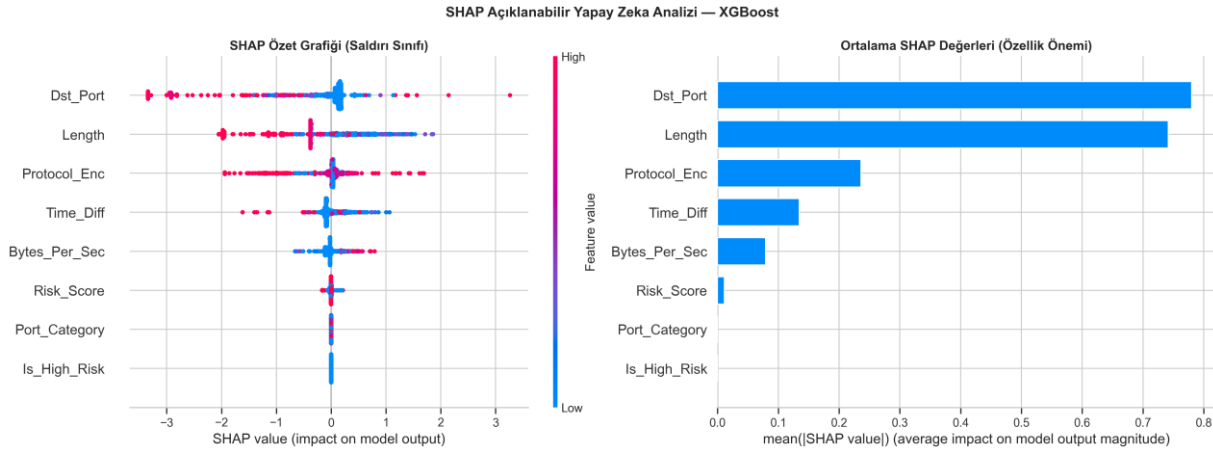
Şekil 2: Confusion Matrix, ROC Eğrisi ve Özellik Önem Derecesi — XGBoost

Model, 12.982 paketlik test setinde şu sonuçları üretmiştir: 10.913 normal paket doğru geçirilmiş (TN), 370 saldırı doğru yakalanmış (TP). Öte yandan 1.338 paket yanlış alarm (FP) ve 361 paket kaçırılan saldırı (FN) olarak kalmıştır.

Metrik	Değer	Yorumu
Precision	%21.7	Her 100 alarmin 21.7'si gerçek saldırı
Recall	%50.6	Saldırıların yarısı yakalanıyor
F1-Score	0.303	Precision-Recall dengesi
Accuracy	%86.9	Genel doğruluk
AUC-ROC	0.825	Güçlü ayırt edici kapasite (1.0 = mükemmel)

AUC-ROC 0.825, modelin rastgele tahminden (%50) belirgin biçimde üstün olduğunu göstermektedir. Precision'ın düşük görünmesinin sebebi veri setindeki ciddi sınıf dengesizliğidir; bu değer, eşik optimizasyonu ile yönetilmektedir.

5. Açıklanabilir Yapay Zekâ (SHAP)

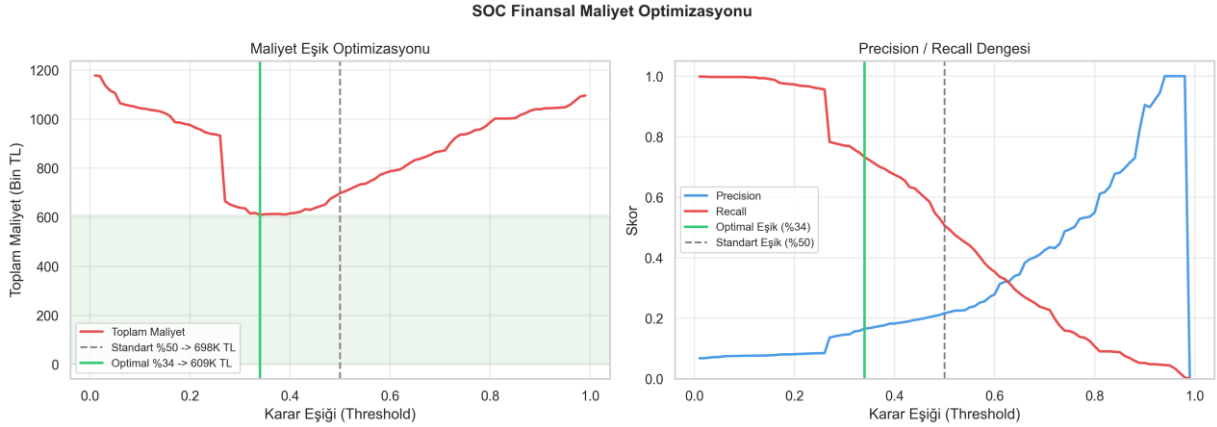


Şekil 3: SHAP Özet Grafiği (sol) ve Ortalama SHAP Değerleri (sağ) — 1.500 paket örnekleme

SHAP, modelin her karar için hangi özelliğe ne kadar ağırlık verdiğini matematiksel olarak açıklar. En güçlü sinyal Dst_Port'tan (0.780) gelmektedir; düşük port numarası, yani SSH, RDP, HTTP gibi kritik servisler, saldırı olasılığını belirgin biçimde artırmaktadır. Length (0.741) ikinci sıradadır; küçük paket boyutu SYN flood imzasıyla örtüşmektedir.

Protocol_Enc (0.236) ve Time_Diff (0.135) orta düzeyde katkı sağlarken, Is_High_Risk ve Port_Category'nin SHAP değeri sıfıra yakındır. Bu iki özellik mevcut modelde ayırt edici güç taşımamaktadır ve gelecek versiyonda gözden geçirilmelidir.

6. Finansal Optimizasyon



Şekil 4: SOC Maliyet Eğrisi (sol) ve Precision/Recall Dengesi (sağ)

Standart veri bilimi yaklaşımı %50 karar eşiği kullanır. Ancak bu eşik maliyet açısından optimal değildir. Eşik %34'e düşürüldüğünde toplam SOC maliyeti 698.046 TL'den 609.081 TL'ye gerilemektedir; bu 88.965 TL'lik net tasarrufa karşılık gelir. Recall %50.6'dan %73.2'ye yükselirken Precision yalnızca %5.1 düşmektedir; bu kabul edilebilir bir değiş tokuştur.

Aşağıdaki duyarlılık analizi, KVKK ihlal olasılığı varsayımı değiştikçe tasarrufun nasıl şekillendiğini göstermektedir:

İhlal Olasılığı	FN Maliyeti	Optimal Eşik	Net Tasarruf
%0.1	300 TL	%71	70.074 TL
%0.5 (ana senaryo)	1.500 TL	%34	88.965 TL
%1.0	3.000 TL	%32	357.354 TL
%2.0 (ağır risk)	6.000 TL	%12	1.271.202 TL

Her senaryoda net tasarruf pozitifdir. En korumacı varsayımda bile 70.074 TL kazanım elde edilmektedir.

Karar eşiği %50 → %34 optimize edildi; 88.965 TL net tasarruf sağlandı.
SOC panelinde öncelikli izlenecek metrikler: Dst_Port, Length, Protocol_Enc.
Her KVKK senaryosunda pozitif tasarruf doğrulandı.

7. Sınırlılıklar ve Gelecek Adımlar

Modelin mevcut sürümünde dört temel kısıt bulunmaktadır. Şifreli trafik (HTTPS/TLS) paket içeriği analiz edilemediğinden kör noktadır. Model yalnızca öğrenilmiş kalıpları tanıdığından sıfır-gün saldırıları tespit edilememektedir. Saldırganlar taktik değiştirirse kavramsal sürüklenme (concept drift) oluşur; bu nedenle 30 günde bir yeniden eğitim önerilir. Son olarak, normal portları kullanan içeriden tehditler modelin görüş alanı dışındadır.

Özet — 64.910 paket | XGBoost | AUC 0.825 | Recall %50.6 | 88.965 TL net tasarruf